



Governance, Risk & Responsible Use

Four questions. Three possible answers.
One habit that keeps useful AI work safe
enough to survive.

Contents

- 01 The Case — can AI do this work?
- 02 The Data — can this information go in?
- 03 The Capability — can I turn this on?
- 04 The People — could this affect someone unfairly?
- 05 The Record — write it down, keep it alive

An ordinary Tuesday

A logistics company has a good year with AI. The tools become ordinary enough that nobody thinks of each use as a decision.

A project manager uploads a customer spreadsheet — names, account numbers — to answer a director's question before lunch.

The company freezes AI use while it investigates. Teams that did nothing wrong lose workflows that worked.

A policy cannot look at the file on your screen. The decisions happen where the work happens.



Four questions before AI does meaningful work:
the Case, the Data, the Capability, the People.
Each has three possible answers — and the middle
one is where professional judgment lives, because
it obliges you to name a reviewer, a control, a
route.



The Case

Can AI do this work at all?

01



Four screens

Reversibility

If the output is wrong, can we catch and undo it before harm happens?

Human judgment

Does the task depend on relationship, care, or context a person should personally own?

Not a scorecard. One criterion usually carries the decision — name it, and the call can be checked, challenged, and improved.

Consequence of error

What happens if it is wrong — trivial, expensive, harmful, regulated, or irreversible?

Accountability

Who answers for the outcome — and can that person meaningfully review what the AI produced?

Three answers

Fully appropriate

Low consequence, reversible, easy to review in the normal course of work. Drafting an FAQ from approved sources. No special gate.

Appropriate with review

Useful — but a specific human check runs before the output is used, sent, or acted on. A billing reply. A shortlist. This answer costs you a commitment.

Inappropriate

The consequence or the responsibility cannot be repaired by review. A final professional determination stays human-owned, however capable the tool.

Forcing every question into yes or no produces recklessness and abandonment both. The middle answer is the demanding one.

Who, what, when

A defined gate

Who — the role that holds the accountability, not whoever is free. **What** — the specific risk this review exists to catch. **When** — before the output is used, not after.

“The account manager checks delivery facts against the dispatch record before the report is sent.” That is a control.

Not a gate

“Someone will check it.” “We'll keep a human in the loop.” “It gets reviewed.” “With appropriate oversight.” Those are intentions.

If you cannot write the review in who / what / when form, the workflow is not ready to run — not “covered by human oversight.”



The Data

Can this information go in — through this route?

02



Three tiers

TIER	WHAT IT COVERS	THE MOVE
 Green	Public material, genuinely anonymised data, internal docs cleared for wide use	No special control
 Yellow	Internal-only documents, names and identifiers, unannounced deal or product material	Check first, or add a control
 Red	Credentials and secrets, regulated or privileged data, third-party confidential material	Only through an explicitly approved path

Unsure between two tiers? Treat it as the higher one. One tier too careful costs a two-minute confirmation; the other way round costs the programme.

Does the task need the identifiers?

No — only the pattern

Remove the identifiers, then check what is left. If it meets your organisation's standard for anonymised data, the tier drops.

If your team still holds the mapping back to real people, it is pseudonymised, not anonymous. “Customer 17” does not lower the tier by itself.

Yes — the specifics are the substance

Redaction is unavailable: the data goes in as it is, and the prior question goes live — is this route approved for this data at all?

That is answered by your admin, policy owner, or contract in advance. Not by you at the keyboard, under deadline.

Controls answer narrow questions

Incognito is not zero retention — it keeps a chat out of history and memory, not out of organisational records.

A sandbox is an execution boundary, not an approval boundary. The data still entered a system.

A project or workspace is a route, not a permission shortcut. Check the files, audience, and configuration.

The real question: is this route approved for this data and this purpose? No privacy feature answers it for you.



The Capability

What authority am I adding to this session?

03



Five checks before you enable

Source — who created or published it? A colleague's recommendation is warmth, not vetting.

Reach — what could it touch? A Skill has no permission dial: it inherits everything the session can reach.

Fit — is that reach proportionate to the job you actually need done?

Outside content — will it read web pages, incoming email, or files you did not author?

Actions — can it send, pay, delete, publish, or approve? Hard-to-reverse changes raise the stakes.

Enable, escalate, decline

Enable

Source known, reach proportionate, task fits, actions controlled. Turn it on in the approved environment.

Escalate

Useful, but something important is unresolved. Name it: “this tool wants write access to the shared drive and the workflow only reads — can that be narrowed?” beats “can I use this?”

Decline

Clearly disproportionate, untrustworthy, or unnecessary — and no review would change that.

Escalating everything is as much a failure as enabling everything. The escalation people skip is the one that names a specific question.

Trusted tool, untrusted content

The quadrant people miss

Trusted publisher, reading outside content. The source check passed — the risk is in what it reads. Instructions hidden in a page or an email can steer the tool: prompt injection.

Routine

Trusted publisher, working only on your own material. Enable and move on.

Do not

Unknown publisher, reading outside content. Both trust questions fail at once.

The source check catches this

Unknown publisher on your own material — the check you already run.

↑ reads outside content · keep send, pay, delete behind a human

trusted → unknown publisher



The People

Could this affect someone unfairly – or
require disclosure?

04



Sample the exclusions

AI narrows a set; humans inspect only the survivors. Shortlists, fraud flags, escalations, ranked leads.

If the system removes a group systematically, nobody notices — the only people positioned to see it were filtered out.

The control: review a sample of what was excluded, not just what remains. Highest stakes where the decision touches employment, benefits, finance, health, or access — where the law may already apply.

Disclosure: rules first, judgment second

First — is it required?

Check law, policy, contract, professional rules, and client commitments. If any of them requires disclosure, the decision is already made.

Then — would it matter?

Would AI involvement reasonably change this person's understanding of the work? Reformatting a table is different from drafting what reads as a manager's personal assessment.

Still uncertain? Escalate the question with your reasoning attached — not a verdict to rubber-stamp.



The Record

Write it down — and know what to do when it goes wrong.

05



One workflow, fifteen minutes

QUESTION	THE CALL	THE COMMITMENT
The Case	Appropriate with review	Account manager checks facts against dispatch before sending
The Data	Yellow — the report needs the identifiers	Approved workspace only; no redaction theatre
The Capability	Enable the connector, read-only	This pipeline may not send
The People	Customers, drivers, staff affected	Phrasing-consistency check; driver disclosure escalated

The Governance Record

The Case

Classification · deciding factor · the gate in who / what / when form.

The Capability

Tools enabled · source and reach · outside content it reads · actions it must not take.

Plus one evidence line: success measure, failure threshold, who monitors, residual risk. A blank field beats a guessed one — write OPEN QUESTION and route it. Re-check when model, data, permissions, or audience change.

The Data

Tier · does the task need the identifiers · fields removed · approved route.

The People

Who is affected · fairness check, exclusions included · disclosure decision · open escalation.

The first hour

The instinct

Delete it quietly. Wait and see. Check whether anyone noticed.

That turns a mistake into concealment — and removes your visibility without removing the data.

The clock matters more than the polish. How the first report is treated decides whether there is ever a second one.

The move

Stop the spread. Record the facts. Report promptly through the incident path. State it plainly. Then follow the incident owner rather than deciding deletion or notification yourself.

Report near misses too — they show where the process is confusing, at no cost.

The one-minute checklist

QUESTION	QUICK CHECK	THE MIDDLE ANSWER REQUIRES
The Case	Can AI do this task responsibly?	A defined gate: who / what / when
The Data	Can this information go through this route?	Minimisation, a control, or a confirmed route
The Capability	Should this tool or authority be on?	A specific security or admin question
The People	Could this affect people or need disclosure?	A fairness check, disclosure, or escalation

“Classify before you act. If the answer is in the middle, name the commitment. Then write down why.”

— the sentence to remember



Now write one down

Pick one workflow you own. Fifteen minutes, one page: the Case, the Data, the Capability, the People, the Evidence — and OPEN QUESTION wherever you don't yet know.